Performance & Security Report

Zamzam Fashion storefront + dashboard (Next.js 16 frontend, .NET 10 API)

Prepared 8 November 2026 · branch feature/admin-visual-identity · not yet deployed

Scope and method

Live checks against the **production build running locally** (`next start` on port 3100, proxying `/api` to the .NET API on port 5055): response headers with `curl -sI`, exposed-path checks, Lighthouse mobile (slow 4G + 4× CPU) for performance, accessibility, best practices and SEO, plus a source review of `next.config.ts`, layout, images and links, and `npm audit`. **Not measured:** TLS, HTTP/2, the CDN and real-user data, because the site is not hosted yet (frontend → Vercel, API → MonsterASP). Lighthouse numbers come from a busy development laptop, so blocking-time values are noisy. CHECK items list the tool that confirms them in Section 4. Section 6 is a modelled calculation.

Status key: **OK** observed and sound · **CHECK** needs a measurement or access not available here · **FIX** issue visible in the code or page.

Summary

The site is in good shape for a pre-launch build. Today's fixes cut the page weight by more than half (home 1,623 → 690 KB, product page 1,508 → 617 KB; product LCP 1.8 s → 0.83 s) and added the missing browser security headers, so Lighthouse now scores **SEO 100, Best Practices 100, Accessibility 96**. The API was already well protected (strict headers, per-IP rate limits, login lockout). The **main performance risk** is JavaScript: the whole storefront hydrates as one client app, blocking the main thread for 2.7–5.8 s on a throttled phone. The **main security gap** is a launch blocker: the frontend proxy does not send the shared `X-Proxy-Secret` yet, so once on Vercel every customer would share one IP-based rate limit (only 10 orders per 10 minutes for the whole shop).

Area	Finding	Status
Rate limiting	Proxy does not send `X-Proxy-Secret`; all shoppers would look like one IP behind Vercel	**FIX**
Page weight	Home 690 KB, product 617 KB (was 1.6 / 1.5 MB); oversized logos and a 163 KB favicon replaced	**OK** fixed today
LCP	Product 0.83 s, home 1.6–2.5 s (target ≤ 2.5 s)	**OK**
Main-thread work	TBT 2.7–5.8 s throttled: one large client-side app hydrates at once	**FIX**
Security headers	nosniff, X-Frame-Options, Referrer-Policy, Permissions-Policy, HSTS, CSP (report-only) now served	**OK** fixed today
X-Powered-By	Framework banner removed	**OK** fixed today
Dashboard indexing	`/admin/*` sends `X-Robots-Tag: noindex`; robots.txt disallows /admin and /api	**OK** fixed today
Secrets / exposure	No secrets in client bundles, no source maps, .env/.git/package.json all 404	**OK**
Dependencies	0 vulnerabilities in production packages; 8 moderate in dev-only lint tooling	**OK**
Colour contrast	Gold 9 px tagline (2.65:1) and a grey 12 px label (2.6:1) below 4.5:1	**FIX**
Sharing / sitemap	No Open Graph image, canonical URL or sitemap yet (need the final domain)	**FIX**
TLS / CDN / HTTP2	Provided by Vercel; confirm after deploy	**CHECK**

1. Performance

Observation	Impact	Status
Next.js 16 with Cache Components; home page prerendered (`x-nextjs-prerender: 1`), product and tracking pages partially prerendered	Fast first HTML; good TTFB once on a CDN	**OK**
Hashed JS/CSS chunks: `Cache-Control: public, max-age=31536000, immutable`	Repeat visits reuse scripts	**OK**
`public/assets` files were served with `max-age=0`; now `max-age=604800, stale-while-revalidate`	Logos and hero no longer re-checked on every page	**OK** fixed today
Navbar logo was a 790 px, 653 KB PNG shown at 60 px; footer logo 163 KB at 64 px; favicon.ico was a copy of the 163 KB logo	~980 KB of a 1.6 MB page; now right-sized WebP (160/448/192 px, 85 KB total) and a 4.7 KB favicon	**OK** fixed today
Below-the-fold images (footer logos, home logo, product grid) `loading="lazy"`; only the navbar logo and hero image are preloaded	Bandwidth goes to what is visible first	**OK** fixed today
Product photos from the API use `srcSet` variants	Phones download small files	**OK**
Fonts via `next/font` (self-hosted, `display: swap`), but 3 families and 13 weights → 11 woff2 preloads	Competes with the hero image on slow networks	**FIX**
Total Blocking Time 2.7–5.8 s (mobile, 4× CPU); most of it is hydrating the single client-side `AppShell` plus Style & Layout	Taps feel slow on cheap phones during the first seconds	**FIX**
CLS 0.002	No layout jumps	**OK**
No video, no third-party scripts, analytics or trackers	Nothing external slows the page	**OK**
Compression, HTTP/2–3 and CDN	Not measurable locally; Vercel provides Brotli and HTTP/2+	**CHECK**

Measured (Lighthouse mobile, slow 4G + 4× CPU, median of 2 runs)

Metric	Good	Before today	Measured now	Where to measure
LCP (product page)	≤ 2.5 s	1.8 s	**0.83 s**	PageSpeed Insights, mobile
LCP (home)	≤ 2.5 s	1.85 s	1.6–2.5 s (noisy)	PageSpeed Insights, mobile
CLS	≤ 0.1	0.002	**0.002**	Lighthouse
Total Blocking Time (lab stand-in for INP)	≤ 200 ms	2.4–4.0 s	**2.7–5.8 s**	PageSpeed / DevTools Performance
Page weight, home	< 1.5 MB	1,623 KB	**690 KB**	DevTools Network
Page weight, product	< 1.5 MB	1,508 KB	**617 KB**	DevTools Network
Requests, home	-	30	30	DevTools Network

Recommendations

- **Trim the fonts.** Keep Cairo for Arabic and DM Sans for Latin, and drop Tajawal or cut the weights to 400/700. That removes about half of the 11 font preloads. It changes how text looks slightly, so it needs the owner's OK.
- **Split the storefront from the dashboard.** Load the admin views with `next/dynamic` so shoppers never download or hydrate dashboard code. This is the main lever on blocking time.
- **Re-measure on Vercel.** Use PageSpeed Insights on the real URL. The laptop numbers include a dev server and the API competing for the same CPU.

2. Security

Observation	Risk	Status
Pages sent no security headers and advertised `X-Powered-By: Next.js`	Clickjacking and MIME sniffing possible; framework fingerprinting	**OK** fixed today
Now served on every page: HSTS, nosniff, `X-Frame-Options: DENY`, Referrer-Policy, Permissions-Policy, CSP in report-only mode; Lighthouse shows no console errors from it	Baseline browser hardening in place	**OK**
API responses: nosniff, DENY, `default-src 'none'` CSP, `X-Robots-Tag: noindex`, CORP same-site	JSON cannot be framed, sniffed or indexed	**OK**
Rate limits on the API: global 300/min per IP; login 5/min with lockout; orders 10 per 10 min; tracking 30/min	Brute force and spam bounded	**OK**
`ClientIpMiddleware` trusts X-Forwarded-For only with `X-Proxy-Secret`, but the Next.js rewrite does not add that header	After deploy every shopper shares Vercel's IP: one busy minute blocks orders for everyone	**FIX**
Admin auth uses an HttpOnly first-party cookie through the `/api` rewrite; no tokens in localStorage	Session cannot be stolen by page scripts	**OK**
No secrets or `NEXT_PUBLIC_*` keys in `.next/static`; no source maps shipped	Nothing sensitive in the browser	**OK**
`/.env`, `/.env.local`, `/.git/config`, `/package.json`, `/next.config.ts` → 404	No configuration exposure	**OK**
Unknown pages and API routes return a plain 404 with no stack trace	No verbose errors	**OK**
All `target="_blank"` links (footer socials, order reference photo) carry `rel="noopener noreferrer"`; social links only render for `https://` URLs	No tab-nabbing or `javascript:` links	**OK**
Shop phone and email shown as `tel:`/`mailto:` links from the settings	Scrapers can collect them; acceptable for a shop that wants contact	**CHECK**
No CAPTCHA on checkout or tailoring forms; protected by server-side validation and rate limits	Fine at launch scale; add Turnstile only if spam orders appear	**OK**
`npm audit`: 0 in production deps; 8 moderate (minimatch ReDoS) in eslint tooling only	Never shipped to users	**OK**
TLS certificate, HTTPS redirect, HSTS effect	Only testable on the real domain	**CHECK**

Headers now in `frontend/next.config.ts`

```
poweredByHeader: false,
async headers() {
  return [
    { source: "/:path*", headers: [
      { key: "Strict-Transport-Security", value: "max-age=63072000; includeSubDomains" },
      { key: "X-Content-Type-Options", value: "nosniff" },
      { key: "X-Frame-Options", value: "DENY" },
      { key: "Referrer-Policy", value: "strict-origin-when-cross-origin" },
      { key: "Permissions-Policy", value: "camera=(), microphone=(), geolocation=(), payment=()" },
      { key: "Content-Security-Policy-Report-Only", value: "default-src 'self'; img-src 'self' data: blob:
https:; ..." } ] },
    { source: "/admin/:path*", headers: [{ key: "X-Robots-Tag", value: "noindex, nofollow" }] },
    { source: "/assets/:path*", headers: [{ key: "Cache-Control", value: "public, max-age=604800, stale-while-
revalidate=86400" }] },
```

```
  ];
}
```

The CSP starts as **Report-Only**: it logs what a strict policy would block (for example product images from Supabase Storage) without breaking the shop. After a week on Vercel with no reports, rename it to `Content-Security-Policy` and narrow `img-src` to the storage host.

Fix for the rate-limit gap: `frontend/src/proxy.ts`

```
import { NextResponse, type NextRequest } from "next/server";
export function proxy(req: NextRequest) {
  const headers = new Headers(req.headers);
  headers.set("X-Proxy-Secret", process.env.PROXY_SHARED_SECRET!);   // same value as Proxy:SharedSecret on the
API
  const url = new URL(req.nextUrl.pathname + req.nextUrl.search, process.env.API_URL);
  return NextResponse.rewrite(url, { request: { headers } });
}
export const config = { matcher: "/api/:path*" };
```

Order and tailoring form hardening

- Keep the server-side length caps and validation (already in the API); the browser checks are only for convenience.
- Rate limits are enough at launch. If fake orders appear, add Cloudflare Turnstile to checkout and tailoring only.
- Do not put customer phone numbers in URLs or logs; the tracking page already needs number + phone.

Preview and launch hygiene

- Turn on Vercel Deployment Protection for preview URLs, so test builds are not public.
- At launch: set `metadataBase` to the real domain, add a canonical tag and `app/sitemap.ts` listing shop and product pages.
- Set `API_URL` and `PROXY_SHARED_SECRET` in Vercel environment variables, never in code.

3. SEO and sharing

Item	Observation	Status
Title and description	Bilingual title and description in `app/layout.tsx`; Lighthouse SEO 100	**OK**
Viewport, `lang="ar"`, `dir="rtl"`	Present	**OK**
robots.txt	Added (`app/robots.ts`): allow /, disallow /admin and /api	**OK** fixed today
Sitemap	Missing; needs the production domain	**FIX**
Canonical URL	Missing; needs the production domain	**FIX**
Open Graph / Twitter card	No og:image (1200×630), og:title or twitter:card; WhatsApp and Facebook shares show no preview	**FIX**
theme-color	Not set (navy #142b4a would tint the mobile browser bar)	**FIX**
Image alt text	All images have alt (Lighthouse image-alt passes); product photo thumbnails use empty alt as decoration	**CHECK**
Headings, buttons, links, form labels	Lighthouse heading-order, button-name, link-name pass	**OK**
Colour contrast	Gold "MADE FOR YOUR STYLE" tagline (#b99664 on #fffaf3, 2.65:1, 9 px) and grey label (#99a1af, 2.6:1) fail 4.5:1	**FIX**

4. How to verify the CHECK items

Goal	Tool / command
Real performance and Core Web Vitals	pagespeed.web.dev on the Vercel URL (mobile and desktop); WebPageTest.org for filmstrip and waterfall
HTTP security headers	securityheaders.com on the Vercel URL; or `curl -sI https://<vercel-domain>/`
TLS, HTTPS redirect, HSTS	MDN HTTP Observatory (developer.mozilla.org/observatory); SSL Labs; `curl -sIL http://<domain>`
Compression, HTTP/2, CDN	Chrome DevTools > Network: Protocol column and `content-encoding: br` on JS
Page weight and lazy loading	Chrome DevTools > Network, throttle to Slow 4G, tick Disable cache
Decorative empty alt on thumbnails	axe DevTools extension on a product page; confirm each empty alt is a duplicate of the main photo
Contact details exposure	Owner decision: keep tel:/mailto: links or show a contact form instead
Real client IP reaches the API	After deploy: place 11 test orders from two networks within 10 min; only the 11th from one network should get 429
Dependency vulnerabilities	`npm audit --omit=dev` in frontend; Dependabot security updates only (already set)

5. Priority action list

1. **Add `proxy.ts` with `X-Proxy-Secret`** (code above) and set the secret on both sides before launch; confirm with the 11-order test in Section 4.

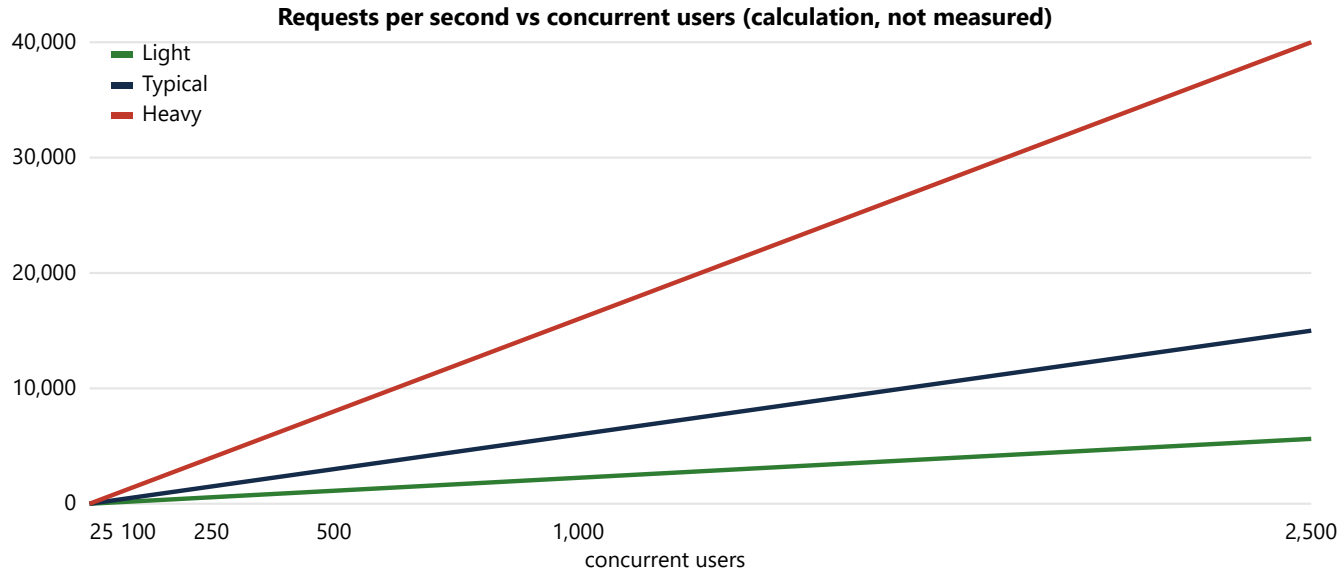
2. **Deploy the API to MonsterASP, then the frontend to Vercel** with `API_URL` set; confirm the headers with securityheaders.com (target A).
3. **Add Open Graph tags, an og:image, theme-color, a canonical tag and `app/sitemap.ts`** once the domain is known; confirm with the Facebook Sharing Debugger.
4. **Lazy-load the dashboard code** with `next/dynamic` so shoppers do not hydrate it; confirm TBT falls in PageSpeed Insights.
5. **Reduce font families and weights** (owner approval, slight visual change); confirm fewer font requests in DevTools.
6. **Fix the two low-contrast texts** by darkening the gold tagline to about #8a6d43 (owner approval); confirm with the Lighthouse accessibility audit.
7. **After a quiet week, switch the CSP from Report-Only to enforced**; confirm with securityheaders.com.

6. Capacity estimate (modelled)

This section is a calculation, not a measurement. No load was generated against the site; the numbers come from the measured request count (30 per home visit) and first-visit size (690 KB).

```
requests/sec = (concurrent users / read time in seconds) x requests per visit
visits/sec   = concurrent users / read time (typical scenario)
bandwidth    = visits/sec x first-visit MB x 8   (Mbps)
transfer/hr  = visits/sec x 3600 x first-visit MB   (GB = MB / 1024)
```

Scenario	Requests per visit	Read time	Reasoning
Light	18	8 s	Cached assets, visitor skims
Typical	30	5 s	Measured request count (Lighthouse, home page)
Heavy	48	3 s	Cold cache, fast scrolling, many product images



Concurrent users	Light (req/s)	Typical (req/s)	Heavy (req/s)
25	56	150	400
100	225	600	1,600
250	563	1,500	4,000
500	1,125	3,000	8,000
1,000	2,250	6,000	16,000
2,500	5,625	15,000	40,000

Bandwidth check (typical scenario, first visit 690 KB)

Concurrent users	Visits/sec	Bandwidth	Transfer per hour
100	20	108 Mbps	47 GB
500	100	539 Mbps	237 GB
1,000	200	1,078 Mbps	474 GB

How to read this

On Vercel's CDN the static request rate is rarely the limit; bandwidth and plan quotas bind first. The real bottleneck is the dynamic API on MonsterASP: product lists, checkout and tracking hit the .NET API and Supabase, and they are already rate-limited per IP (which only works once item 1 of the action list is done). Check the Vercel plan's data-transfer allowance and the MonsterASP plan's CPU and connection limits before a campaign. Confirm the real limits with `zamzam-fashion-loadtest.js` (delivered with this report), run with k6 against a deployment you own, ideally staging, outside peak hours.

Assumptions: 30 requests and 690 KB per first visit (Lighthouse, home page, local build); read times of 8/5/3 s; repeat visits are much lighter thanks to caching. **Limitations:** findings come from a local production build at the time of review; TLS, CDN and real-user data were not available; no intrusive or active security testing was performed. Sharing the PageSpeed Insights run, the securityheaders.com result and the k6 summary from the deployed site would let this report be updated with real numbers.